

WEB APPLICATION PENETRATION TESTING

Cybersecurity — Project 3

Student Name	Muhammad Haseeb Farooq
Date	9/8/2026
Project	Web Application Penetration Testing
Key Tools	Burp Suite, DVWA, SQLmap, OWASP

Project Overview

This project examines common web application security weaknesses in an authorized laboratory environment. The material covers OWASP-aligned vulnerabilities, secure coding practices, DVWA setup, and Burp Suite-based testing.

OWASP Top 10 — Critical Web Vulnerabilities

Rank	Vulnerability	Impact
1	Broken Access Control	Unauthorized access to data
2	Cryptographic Failures	Exposure of sensitive data
3	Injection	SQL injection, command injection
4	Insecure Design	Missing security controls
5	Security Misconfiguration	Default credentials, exposed configs
6	Vulnerable Components	Using outdated libraries
7	Authentication Failures	Weak password/session handling
8	Software Integrity Failures	Unsigned updates
9	Logging & Monitoring Failures	No audit trail
10	SSRF	Server-side request forgery

02 / SQL Injection & Cross-Site Scripting

SQL Injection Attacks

SQL injection occurs when untrusted input is incorporated into a database query without appropriate parameterization. The defensive approach is to separate query structure from user-supplied values.

Secure parameterized-query pattern

```
query = "SELECT * FROM users WHERE username=? AND password=?"
cursor.execute(query, (username, password))
# Parameters are supplied separately from the SQL statement
```

Cross-Site Scripting (XSS)

XSS involves untrusted content being interpreted as executable browser-side code. Applications should encode output for its specific context and use templating systems that escape by default.

Defensive output encoding

```
PHP: echo htmlspecialchars($_GET['comment']);
Jinja2 / Django: use the framework's automatic HTML escaping for template output.
```

DVWA — Vulnerable Web Application

DVWA (Damn Vulnerable Web Application) is intentionally insecure and is designed for controlled penetration-testing practice.

Typical laboratory setup

1	Place DVWA in the local web-server directory.
2	Configure the MySQL database for the application.
3	Open the local DVWA installation in the browser.
4	Use the lab account configured for the local environment.

Common DVWA vulnerability areas

- SQL Injection (including advanced and blind testing)
- Reflected and Stored XSS
- File Upload security weaknesses
- Authentication and session security
- CSRF protection

03 / Burp Suite Testing Workflow

Burp Suite — Professional Testing Tool

Burp Suite can be used in an authorized lab to intercept HTTP traffic, inspect parameters, modify requests, and replay them to understand application behavior.

Feature	Primary use
Proxy	Intercept browser requests, inspect parameters, and view responses
Scanner	Automated identification of common web vulnerabilities
Intruder	Controlled parameter testing and fuzzing
Repeater	Modify and resend individual requests

Authorized lab workflow

1. Start the local DVWA laboratory environment.
2. Configure the browser to route traffic through the local Burp proxy.
3. Browse the application and observe intercepted requests.
4. Identify parameters and application behavior that require security testing.
5. Use Repeater for controlled request modification and verification.
6. Record evidence, affected components, impact, and recommended remediation.

Testing Focus

Area	What to verify
Input validation	Unexpected or malformed input is handled safely
Authentication	Incorrect credentials do not grant access
Authorization	Users cannot access resources outside their permissions
Session security	Session identifiers and state transitions are protected
Output encoding	Untrusted content is encoded before rendering
CSRF controls	State-changing requests require appropriate anti-CSRF protection

04 / Security Assessment Checklist

Use this checklist to document results from the controlled laboratory assessment. Mark each item only after the corresponding test has been performed and evidence recorded.

Test Case	Expected Result	Status
DVWA setup	Local application loads successfully	■
Proxy configuration	HTTP requests are visible in Burp	■
SQL injection review	Input handling prevents query manipulation	■
XSS review	Untrusted output is safely encoded	■
CSRF review	Unauthorized state-changing actions are blocked	■
File upload review	Uploaded content is safely validated and stored	■
Authentication review	Invalid credentials do not authenticate	■
Authorization review	Restricted resources remain inaccessible	■
Reporting	Findings include evidence and remediation	■

Assessment Record

Student	Muhammad Haseeb Farooq
Date	9/8/2026
Environment	Authorized local laboratory / DVWA
Primary tools	Burp Suite, DVWA, SQLmap, OWASP

End of Project 3 — Web Application Penetration Testing